

Code Audit: Authentication & Access

Structural validation, dead code scan, and vulnerability identification

DATE AUDITED	MODULE SCOPE	PLATFORM VERSION
June 15, 2026	src/app (auth/invite), src/components/auth, src/lib/auth	Next.js 16 (React 19)

Executive Summary

A comprehensive code audit was executed on the Authentication & Access module. The module is structurally sound, featuring secure stateful session management, standard password hashing via bcryptjs, and database-backed MFA integration. However, several optimization and correctness opportunities were identified: a completely unused and redundant API route, a static spinner UI due to missing CSS keyframes, dangling invite tokens in standard registration pathways, and a global bypass of TypeScript compilation checks via @ts-nocheck in 12 separate source files.

19

Files Scanned

2

Critical Issues

4

Warning Gaps

13

Clean Components

Module Files & Scan Status

File Path	Type	Size (Lines/Bytes)	Audit Status
src/app/login/page.tsx	Client Page	353 lines / 11,544 B	CLEAN
src/app/register/page.tsx	Client Page	179 lines / 6,067 B	CLEAN
src/app/invite/page.tsx	Client Page	294 lines / 9,967 B	ISSUES FOUND
src/app/api/auth/login/route.ts	API Route	149 lines / 4,532 B	WARNING
src/app/api/auth/logout/route.ts	API Route	23 lines / 572 B	CLEAN
src/app/api/auth/mfa/disable/route.ts	API Route	62 lines / 1,733 B	CLEAN
src/app/api/auth/mfa/setup/route.ts	API Route	49 lines / 1,340 B	CLEAN
src/app/api/auth/mfa/verify/route.ts	API Route	75 lines / 2,198 B	CLEAN
src/app/api/auth/register/route.ts	API Route	376 lines / 15,686 B	WARNING
src/app/api/auth/session/route.ts	API Route	50 lines / 1,469 B	CLEAN

File Path	Type	Size (Lines/Bytes)	Audit Status
src/app/api/auth/verify-password/route.ts	API Route	42 lines / 1,474 B	CLEAN
src/app/api/auth/verify-session/route.ts	API Route	21 lines / 592 B	UNUSED ENDPOINT
src/app/api/invite/validate/route.ts	API Route	61 lines / 1,857 B	CLEAN
src/components/auth/PermissionGate.tsx	React Component	27 lines / 651 B	CLEAN
src/lib/auth/getAuthSession.ts	Helper Lib	34 lines / 992 B	CLEAN
src/lib/auth/mfa.ts	Helper Lib	76 lines / 2,494 B	WARNING
src/lib/auth/password.ts	Helper Lib	19 lines / 470 B	CLEAN
src/lib/auth/permissions.ts	Helper Lib	40 lines / 1,220 B	CLEAN
src/lib/auth/session.ts	Helper Lib	229 lines / 6,600 B	CLEAN

Audit Findings & Analysis

Obsolete Dead Endpoint: /api/auth/verify-session

Severity: **Critical (Dead Code)** Location: src/app/api/auth/verify-session/route.ts

OBSOLETE

The route handler `verify-session/route.ts` is completely redundant and represents dead code. The main application uses `/api/auth/session` (inside `AuthProvider.tsx`) to perform session verification and state recovery. `/api/auth/verify-session` is listed in the middleware public route configuration but is never called by any code.

Obsolete Endpoint implementation

```
// src/app/api/auth/verify-session/route.ts
// This file can be safely deleted; its functionality is duplicate of `/api/auth/
export async function GET(request: NextRequest) {
  const sessionToken = request.cookies.get('session_id')?.value;
  if (!sessionToken) {
    return NextResponse.json({ error: 'No session token' }, { status: 401 });
  }
  const sessionData = await verifySession(sessionToken);
  if (!sessionData) {
    return NextResponse.json({ error: 'Invalid session' }, { status: 401 });
  }
  return NextResponse.json(sessionData);
}
```

RECOMMENDATION

Delete `src/app/api/auth/verify-session/route.ts` entirely and remove its entry from the `src/middleware.ts` configurations to reduce code footprint and clean up security surfaces.

TypeScript Compile Error in Client Component

COMPILE ERROR

Severity: **Critical (Broken compilation)** Location: src/app/invite/page.tsx

At line 42, `handleSubmit` references `React.FormEvent`. However, `React` itself is not imported on line 3 (only `{ useEffect, useState, Suspense }` are imported). In strict TypeScript configurations, this triggers a compiler error: `Cannot find name 'React'`.

Missing import and usage

```
// Line 3
import { useEffect, useState, Suspense } from 'react'; // Missing default 'React'
```

```
// Line 42
const handleSubmit = async (e: React.FormEvent) => { // <-- Throws: Cannot find n
  e.preventDefault();
  // ...
}
```

RECOMMENDATION

Add `import React, { useEffect, useState, Suspense } from 'react';` or import `FormEvent` directly and define the type signature as `e: FormEvent`.

Dangling Invite Tokens after Email-Based Registration

LOGIC GAP

Severity: **Warning (Logic Gap)** Location: `src/app/api/auth/register/route.ts`

In the registration API, a user can sign up via two branches: Branch A (via token-based link) and Branch B (via business email matching a pending database user). In Branch A, the database transaction correctly clears the token state: `inviteToken: null`, `inviteTokenExpiry: null`. However, in Branch B, these fields are not updated.

Branch B Transaction Logic

```
// src/app/api/auth/register/route.ts - Branch B (Line 110)
const updatedUser = await tx.user.update({
  where: { id: existingUser.id },
  data: {
    passwordHash: hashedPassword,
    firstName,
    lastName,
    // Gap: inviteToken and inviteTokenExpiry are not cleared!
  },
});
```

RECOMMENDATION

Update Branch B's user update transaction to clear the invite token fields:

```
data: {
  passwordHash: hashedPassword,
  firstName,
  lastName,
```

```
inviteToken: null,  
inviteTokenExpiry: null,  
}
```

Broken CSS Animation Keyframes for Page Spinner

UI GLITCH

Severity: **Warning (UI Bug)** Location: src/app/invite/page.tsx

The loader element on the invite validation page uses a spinner style configured with animation: 'spin 0.8s linear infinite'. However, there are no keyframes declared for spin anywhere in the inline CSS record. As a result, the spinner is statically rendered and does not rotate.

Styles definition (Line 272)

```
spinner: {  
  width: 36,  
  height: 36,  
  border: '3px solid #e8eaf6',  
  borderTop: '3px solid #667eea',  
  borderRadius: '50%',  
  animation: 'spin 0.8s linear infinite', // Keyframes not declared  
  margin: '0 auto',  
}
```

RECOMMENDATION

Since React inline styles do not support keyframes directly, inject keyframes through a global layout stylesheet or add a <style> block to the React structure that declares the keyframes:

```
@keyframes spin {  
  from { transform: rotate(0deg); }  
  to { transform: rotate(360deg); }  
}
```

Global TypeScript Compiling Bypass (@ts-nocheck)

QUALITY

Severity: **Warning (Code Quality)** Location: 12 Module Files

Critical files in the Authentication module (including routes, hashing utilities, and session handlers) start with `// @ts-nocheck`. This bypasses compile-time verification globally, masking implicit any errors, potential type bugs, and breaking changes.

RECOMMENDATION

Incrementally remove the `// @ts-nocheck` annotations, fix the underlying type mappings, and enforce strict type safety checks to ensure code reliability across environments.

Fallback Key in Production MFA Encryption

SECURITY

Severity: **Warning (Security Vulnerability)** Location: `src/lib/auth/mfa.ts`

The encryption key utilized for AES-256-GCM secret hashing defaults to a fallback string: `'default-fallback-key-must-be-changed-in-prod-environments'`. In environments where the variable is unset or missing, it will silently encrypt secrets with a guessable key, leaving customer data vulnerable.

Vulnerable Configuration (Line 6)

```
const ENCRYPTION_KEY = process.env.MFA_ENCRYPTION_KEY || 'default-fallback-key-mu
```

RECOMMENDATION

Ensure that an environment variable check throws a configuration error if `MFA_ENCRYPTION_KEY` is missing during startup or compilation in production environments, rather than falling back to a plain text string.

Remediation Plan

Priority Action Checklist

- ☐ Delete Unused `verify-session` API Handler

Remove `src/app/api/auth/verify-session/route.ts` and clear the reference in `src/middleware.ts`.

☐ **Resolve Typescript Compiler Issue in Invite Page**

Add `import React` or directly import `FormEvent` in `src/app/invite/page.tsx`.

☐ **Clear Invite Tokens in Branch B of Register Endpoint**

Update user update query in `src/app/api/auth/register/route.ts` to null out `inviteToken` and `inviteTokenExpiry`.

☐ **Implement CSS keyframes for Page Spinner**

Inject `@keyframes spin` in the `src/app/invite/page.tsx` layout context.

☐ **Disable Fallback MFA Encryption Key**

Enforce a check that crashes/stops server startup if `process.env.MFA_ENCRYPTION_KEY` is undefined in production.

☐ **Remove `ts-nocheck` and `strict-type` Auth module**

Remove the `// @ts-nocheck` directives and resolve typescript compiler issues throughout the `auth` folder.